

인젝션 발표 전반적인 흐름

1. Injection의 의미와 종류 소개

- Injection 공격은 공격자가 코드를 입력하여 공격하는 공격 유형 (XSS, CSRF, OS 인젝션)
- Injection에서의 공격 기법들 소개
 - OS Command Injection (CRLF나 &&나 |와 같이 시스템에서 특수한 동작으로 인식하는 문자열을 삽입하여 공격하는 기법)
 - SQL Injection
 - In-Band SQL Injection
 - Blind Injection

2. Command Injection 실습 문제 풀이

- DVWA에서 제공하는 코드를 함께 보면서 원리 설명 및 공격 결과 확인

3. 관계형 데이터베이스 간단 소개 (with Maria DB)

- Maria DB는 관계형 데이터베이스 구조로 데이터를 관리하는 DBMS 중 하나
- 관계형 데이터베이스는 테이블 구조로 정보를 저장하며 테이블끼리 서로 관계를 가짐
- 관계를 갖는다는 것은 한 테이블이 다른 테이블을 참조하고 있는 열이 있다는 것을 의미
- 참조되는 테이블의 열 데이터를 통해서 참조하고 있는 테이블의 데이터를 조회할 수 있음
- 지금껏 DB를 생성해 왔는데 DB를 하나의 공간으로 생각해 보기로한다.
- 생성된 하나의 공간 안에 여러 개의 테이블을 생성할 수 있다. (DB와 테이블의 관계 설명)

4. SQL문 (Select Where 문) 소개

- Select문은 DB 안에 있는 테이블을 조회할 때 쓰이는 SQL문
- Select의 구조 : Select [열 이름] From [데이터베이스 이름];
- 간단한 문제를 통해서 사람들과 소통할 예정
(예시 테이블을 보여주며 특정 열의 데이터를 조회하려면 명령어가 어떻게 되는지 묻기)
- Select Where 문을 통해서 원하는 조건의 데이터를 조회할 수 있음
- 구조 : Select [열 이름] From [데이터베이스 이름] Where [조건문];
- 간단한 문제를 통해서 사람들과 소통할 예정
(예시 테이블을 보여주며 특정 열의 데이터를 조회하려면 명령어가 어떻게 되는지 묻기)

5. 기본 SQL Injection 소개

- DVWA 웹 페이지에서 소스 코드를 보면서 어떻게 공격이 성립되는지 설명
- 같이 실습하면서 설명

6. Blind Injection 소개

- 웹 화면에 주요 데이터가 유출되는 것과는 다르게 참과 거짓의 결과만이 웹 화면에 나타난다는 차이점 설명 (Blind와 기본 SQL Injection 비교)

- 예시를 통해서 DB의 이름, 혹은 이름의 길이를 유추하여 알 수 있다는 점과 알아낼때까지 반복적으로 Injection공격을 해야 하는 점 설명
- sqlmap 프로그램은 이렇게 반복해야 하는 것을 자동화 하여 DB정보부터 더 나아가 테이블 안에 있는 데이터를 알아낼 수 있다는 것을 설명

7. sqlmap 도구 소개

- sqlmap은 여러 가지 Injection 공격을 시행하여 해당 웹 사이트가 Injection 공격에 취약한지 검사하는 도구임을 설명
- 주요 옵션들을 설명하며 함께 실습을 해서 DB, TABLE, TABLE 속 데이터를 확인할 수 있음을 설명
- 쿠키는 로그인했을 시 서버가 클라이언트를 식별하기 위해서 사용하거나 부가적인 서비스를 제공하기 위해서 사용하는 Key : Value 구조의 짧은 문자열 데이터임을 설명
- + DVWA에서 생성되는 SESSID, security(보안 난이도) 쿠키를 보여주면서 설명할 예정

sqlmap에서의 주요 옵션들	
옵션	설명
-u [URL]	취약점 점검을 진행할 URL을 지정해주는 옵션 **[URL]은 submit 한번 클릭하고 생긴 URL로 지정** 이유는 sqlmap은 SQL Injection 점검을 어디에 해야 하는지 모르기 때문에 알려줘야 한다
-dbs	취약점 점검 시 현재 사용중인 DB 목록을 보여주는 옵션
-cookie="쿠키 값"	로그인 했을 때 필요한 옵션으로 특정 사용자의 쿠키 값을 가지고 점검을 진행
-D [DB이름] --tables	해당 DB에 있는 테이블 목록을 보여주는 옵션
--batch	sqlmap 실행 시 여러 가지 물어보는데 이걸 안 물어보고 그냥 기본값으로 점검을 진행하도록 해주는 옵션
-T [테이블 이름] --columns	정보를 추출할 테이블
-T [테이블 이름] --dump	테이블 속 저장되어있는 데이터를 확인하는 옵션 (사전 공격을 통해서 해시화된 비밀번호를 알아낼 수 있다)